Pr Out STUDIO

プロトタイピングで
ガンガン作って攻めるための、
最低限の身の丈セキュリティ話

第2回 ものづくり医療研究会

2026/11/15（日）13:45〜 ふれあい貸し会議室 秋葉原No53



菅原のびすけ

- プロトタイピングスクール「プロトアウトスタジオ」
- デジタルハリウッド大学大学院 非常勤講師
  - プロダクトプロトタイピング

個人活動

- IoTLT（国内最大のIoTコミュニティ）主催
- Developers Summit 2025 ベストスピーカー 1位
- LINE API Expert / Microsoft MVP / IBM Champion

AIで医療者もアプリが作れる時代ですね

- 受付・順番待ちシステム
- 問診フォーム
- 院内の業務改善アプリ

産院の院長がChatGPTで患者呼び出しシステムを作った



産院のいんちょ (@A_Mochizuki) on X

X (formerly Twitter) / 2026-10-16

Pythonは書けないけど、院内LANから呼べる待合室の呼び出しシステム（@A_Mochizuki さん 2026/10/16）

今日のメッセージ

セキュリティが心配だから作らない、ではなく

「ここは意識してます」と自信を持って言えるから、
ガンガン作れる

今日のアジェンダ

- 1. 集めない
- 2. 持たない
- 3. 分ける
- 4. 身の丈の運用
- 5. まとめ

今日のアジェンダ

- **1. 集めない**
- 2. 持たない
- 3. 分ける
- 4. 身の丈の運用
- 5. まとめ

AIに受付システムを作らせると、とりあえず全部聞いてくる

- 氏名
- 生年月日
- メールアドレス
- 電話番号

予約の時点で、生年月日まで聞かれる



以下の必要項目に入力をお願いします

診療されるご本人のお名前

姓 *
例) 山田

名 *
例) 太郎

セイ *
例) ヤマダ
カナまたはアルファベット

メイ *
例) タロウ
カナまたはアルファベット

生年月日 *
年 月 日

性別 *
男性 女性

電話番号 *
ハイフンなしで入力

メールアドレス *
予約の完了メールなどを受信します
メールアドレスを持っていない
メールアドレスは必須です

郵便番号 *
例) 1234567

住所 *
日本語

ある医療機関のWeb予約フォーム（必須：氏名・フリガナ・生年月日・性別・電話番号・メール・郵便番号・住所）

来院したら、問診票でもまた生年月日を書く

順番を管理するだけなら受付番号で済むかも

- 氏名・生年月日・メール・電話 => **A-023**
- 患者さんとの対応が必要なら、既存の受付システム側で持てないか

受付番号も患者さんと結び付くなら個人情報になり得る

集めない

持っていない情報は漏らせない

紙の問診票でも、生年月日とか無駄に聞くのはやめよう

- アプリでも紙でも、書いてもらった情報は持つことになる
- 紙もなくす、置き忘れる、見られる
- => 紙の問診票からも、要らない項目を消す

修学旅行で名簿の入ったリュックを紛失



修学旅行中に教員がリュックサックを紛失　2年生226人全員の個人情報流出の可能性　広島県立の高校で（RCC中国放送） - Yahoo!ニュース

Yahoo!ニュース

AIが作ったフォームから、人間が項目を削る



作らない機能を決めることもセキュリティ設計

今日のアジェンダ

- 1. 集めない
- **2. 持たない**
- 3. 分ける
- 4. 身の丈の運用
- 5. まとめ

持たない

毎回生年月日を入れさせたくない

でも、**DBには貯めたくない**

病院の個人PCでサポート詐欺

2026 06/03 wed お知らせ

個人情報漏洩に関するご報告とお詫び

令和8年6月3日

患者様各位

藤田医科大学病院
病院長　今泉 和良

愛知県の藤田医科大学病院で個人情報漏えいの可能性、規定に反して情報を持ち出した個人PCがサポート詐欺に

INTERNET Watch / 2026-06-05



サポート詐欺で発覚 ～ 産婦人科医師が不適切な状態で患者データ保管 | ScanNetSecurity

ScanNetSecurity

2回目からはパスキーでログイン

- パスワードを作らせない
- 使い回しを防ぎやすい
- フィッシングに強い
- パスワード再設定を作らなくていい

参考: Setlogの登録画面

受付QR＋一時トークンで問診フォームを開く

- 1. 受付で患者さんごとのQRを発行
- 2. スマホで問診フォームを開いて回答
- 3. 回答は問診IDに紐付けて保存
- 4. 患者IDとの対応は既存の患者管理システム側で

QRを持っているだけで本人とは言い切れない（渡し間違い、転送、盗撮）

今日のアジェンダ

- 1. 集めない
- 2. 持たない
- **3. 分ける**
- 4. 身の丈の運用
- 5. まとめ

患者DB・問診DB・対応表を分ける

患者DB

- 患者ID
- 氏名
- 生年月日

漏れても問診内容は出ない

問診DB

- 問診ID
- 症状、既往歴
- 暗号化

漏れても氏名は出ない

対応表

- 患者IDと問診IDの対応だけ
- 別の場所に置く

見られる人を絞る

IDを分けただけでは匿名化にはならない

DBだけじゃなく、サーバーや場所、ネットワークも分けておく

- 1. 同じDBの中でテーブルを分ける
- 2. 別のDBに分ける
- 3. 別のサーバーに分ける
- 4. 別のネットワーク・クラウド環境に分ける
- 5. アカウント・アクセス権限を分ける
- 6. 暗号鍵の管理も分ける

分けすぎると運用が大変になるので、身の丈で

鍵と権限も分ける

- アプリごとに必要なDBにだけアクセスさせる
- 患者情報と問診内容を取るAPIを分ける
- 受付スタッフと医師で見える情報を分ける
- 一括ダウンロードと管理者権限を絞る
- ログやバックアップにも個人情報が残る

集めない・持たない・分ける

漏れても被害が小さくなる設計

今日のアジェンダ

- 1. 集めない
- 2. 持たない
- 3. 分ける
- **4. 身の丈の運用**
- 5. まとめ

「URLを知ってる人だけ」はアクセス制御じゃない

- robots.txt => セキュリティの仕組みじゃない
- noindex => 検索に出にくくするだけ
- => 見せたくないデータには**認証とアクセス制御**

例: ChatGPT の共有リンクの会話が、検索結果に出ていた（2025年8月）

介護・医療の設定ミス

福岡県働きやすい介護職場認証制度事業における個人情報の漏えい事案について - 福岡県庁ホームページ

福岡県庁ホームページ



表示されるべきでない患者一覧が閲覧可能に ～ 大阪公立大学医学部附属病院 | ScanNetSecurity

ScanNetSecurity



ニチイ学館、介護サイトで個人情報漏洩のおそれ―583名分、99名は健康状態・障がい情報を含む|セキュリティニュースのセキュリティ対策Lab

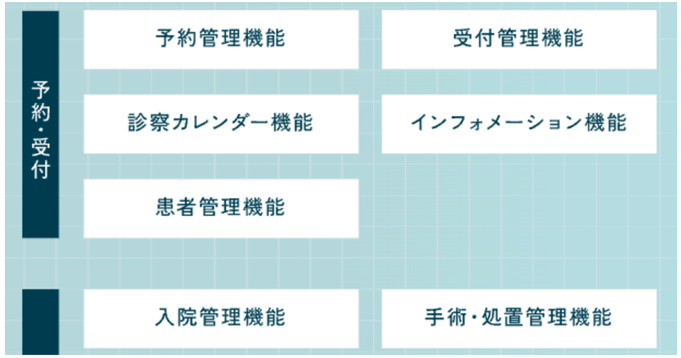
合同会社ロケットボーイズ - セキュリティ 情報漏洩のニュースサイト セキュリティ対策Labの運営とBtoB マーケティング コンサル 支援 / 2026-10-06

予約サイト、患者アプリ、問診データ



ホワイトエッセンス、約105万アカウントの個人情報流出　8月発表の不正アクセス調査で判明

ITmedia NEWS



メドレーの産婦人科向けシステムに不正アクセス、患者の個人情報漏えいか　最大787の医療機関が対象

ITmedia NEWS



資生堂、利用者情報が2515件流出　肌の測定結果など - 日本経済新聞

日本経済新聞 / 2026-11-06

学習に使われない ≠ ログが残らない

- ChatGPT Business / Enterprise => 原則、業務データを学習に使わない
- OpenAI API => デフォルトで学習に使わない
- Gemini API => 有料扱いかどうかで条件が変わる
- 試作は**ダミーデータ**で

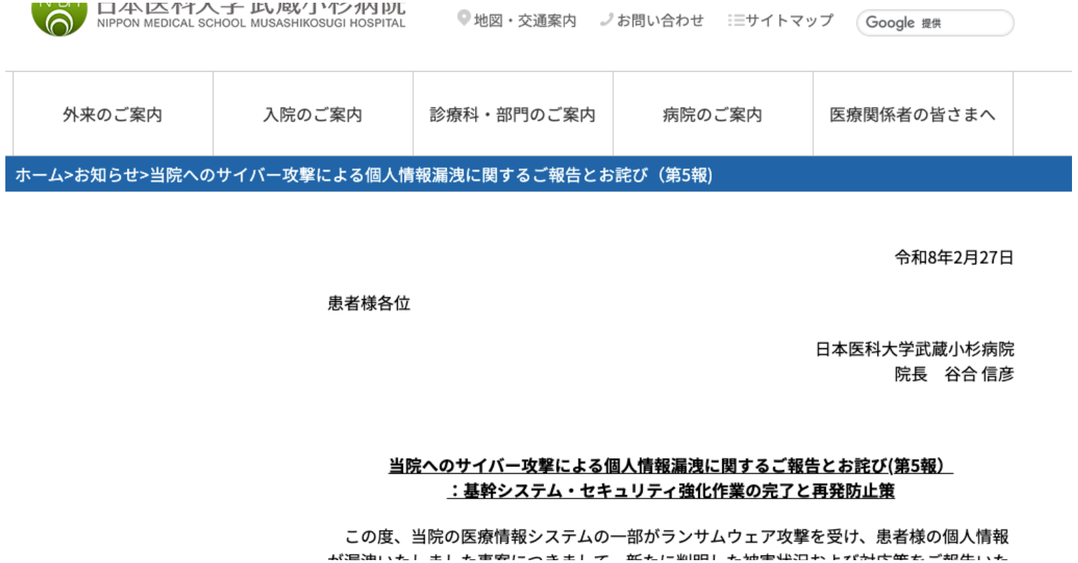
規約は変わるので、使う前に公式のページで確認する

医療機器の保守用VPNからランサムウェア



約13万人の患者情報が漏えい ～ 日本医科大学武蔵小杉病院へのランサムウェア攻撃 | ScanNetSecurity

ScanNetSecurity



日本医科大学武蔵小杉病院、ランサムウェア被害の詳細および対策を発表、患者・職員約13万人の個人情報が漏えい

INTERNET Watch / 2026-03-04

今日のメッセージ（再掲）

セキュリティが心配だから作らない、ではなく

「ここは意識してます」と自信を持って言えるから、
ガンガン作れる

まとめ

- 動くアプリと安全なアプリは違う
- **集めない・持たない・分ける**で、漏れても被害が小さい設計に
- 限定公開URLはアクセス制御じゃない
- 作ったあとの更新まで考える

=> 「そもそも集めてない」「分けてある」と自信を持って言えるようにして、ガンガン作ろう